Implicazioni organizzative della Direttiva NIS2

Il supporto degli standard internazionali e il ruolo strategico del CISO nell'attuazione della normativa

Relatore:
Chiar.mo Prof. Edoardo Mollona

Corso di Laurea in
Informatica per il Management

Presentata da:
Francesco Maria Fuligni

Obiettivi

- Analizzare le implicazioni organizzative della Direttiva NIS2
- Chiarire il rapporto tra strumenti volontari quali ISO 27001 e NIST CSF con la Direttiva NIS2
- Indagare il ruolo e le responsabilità del CISO nell’adempimento degli obblighi normativi

Metodologia

- Analisi delle misure prescritte da NIS2 e del loro impatto sulle organizzazioni
- Confronto strutturato tra ISO 27001, NIST CSF e NIS2
- Indagine sul ruolo del CISO mediante interviste a professionisti del settore

Misure richieste da NIS2 e implicazioni

Art. 20: Governance e responsabilità	Attribuzione formale della responsabilità della sicurezza informatica agli organi di gestione
Art. 21: Misure di sicurezza informatica	Politiche di cybersicurezza aziendale Implementazione di controlli e misure di sicurezza Monitoraggio dei fornitori Formazione dei dipendenti e degli organi di gestione
Art. 23: Notifica degli incidenti significativi	Obblighi e tempistiche per la segnalazione di incidenti Designazione di un punto di contatto interno all'azienda

Impatto sulle organizzazioni

Dimensione aziendale	Disponibilità di risorse	Maturità dei sistemi	Impatto NIS2
Piccola	Limitata	Assente o minima	**Molto elevato**
Piccola/media	Media	Iniziale	**Elevato**
Media	Media	Intermedia	**Medio**
Medio/grande	Elevata	Elevata	**Basso**
Grande	Elevata	Completa	**Molto basso**

ISO 27001 – Annex A

A.8 Controlli tecnologici

A.5 Controlli organizzativi



A.7 Controlli fisici

A.6 Controlli sul personale

06

Implicazioni della certificazione ISO 27001

Coinvolgimento attivo del CdA.

Responsabilizzazione degli organi di gestione, ma non sufficiente.

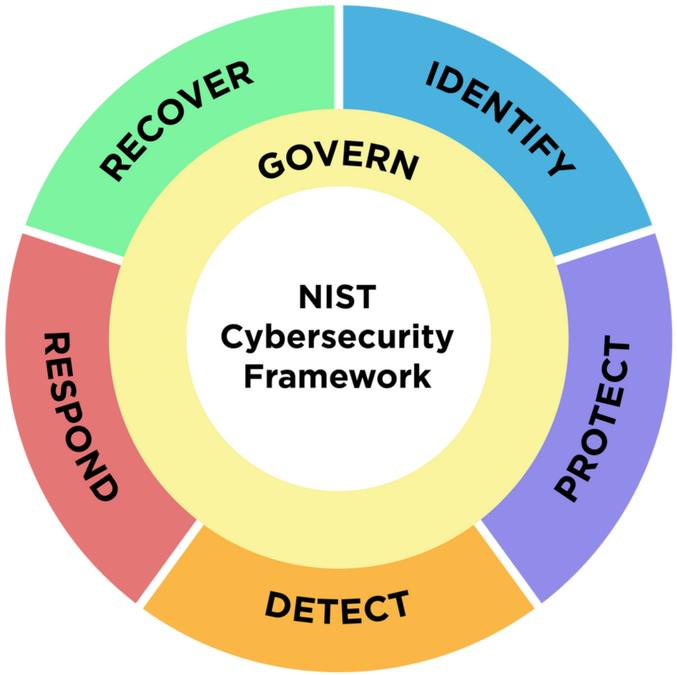
Adozione di controlli e meccanismi di valutazione delle prestazioni.

Necessaria una rivalutazione del rischio coerente con NIS2.

Solida struttura di governance e documentazione delle misure per la certificabilità.

Utile in caso di audit esterni e per dimostrare accountability.

NIST CSF 2.0 – Core Functions



Implicazioni dell’adozione del NIST CSF

Fornisce una solida base di procedure di sicurezza.



Necessario integrare la sicurezza della supply chain, responsabilità del CdA e notifica degli incidenti.

Le funzioni Identify e Protect definiscono la condizione di normale operatività.



Analogamente, NIS2 stabilisce le misure minime da implementare.

Le funzioni Detect, Respond e Recover strutturano il contesto in caso di incidenti.



Analogamente, NIS2 regola i requisiti di sicurezza in fase di risposta e recupero.

Mappatura NIS2 – ISO 27001 – NIST CSF

NIS2 Articolo 21(2)	Controlli ISO 27001	Funzioni NIST CSF
(a): Analisi dei rischi e politiche	A.5, A.8	GV, ID, PR
(b): Gestione degli incidenti	A.5, A.6, A.8	GV, ID, DE, RS, RC
(c): Continuità operativa e gestione crisi	A.5, A.7, A.8	GV, ID, PR, DE, RC
(d): Sicurezza della supply chain	A.5, A.8	GV, ID
(e): Sviluppo sicuro e manutenzione	A.5, A.7, A.8	GV, ID, PR, DE
(f): Valutazione delle misure	-	GV, ID
(g): Igiene informatica e formazione	A.6, A.8	ID, PR
(h): Crittografia e cifratura	A.5, A.8	ID, PR
(i): Sicurezza personale, accessi e asset	A.5, A.6, A.7, A.8	GV, ID, PR, DE

Mappatura NIS2 – ISO 27001 – NIST CSF

Articolo 20
Attribuisce agli organi di gestione la diretta responsabilità della sicurezza informatica dell'organizzazione.

Articolo 23
Stabilisce le modalità e le tempistiche con cui i soggetti NIS2 devono notificare gli incidenti significativi.



Necessario integrare
ISO 27001 e NIST CSF

La figura del CISO

Compiti



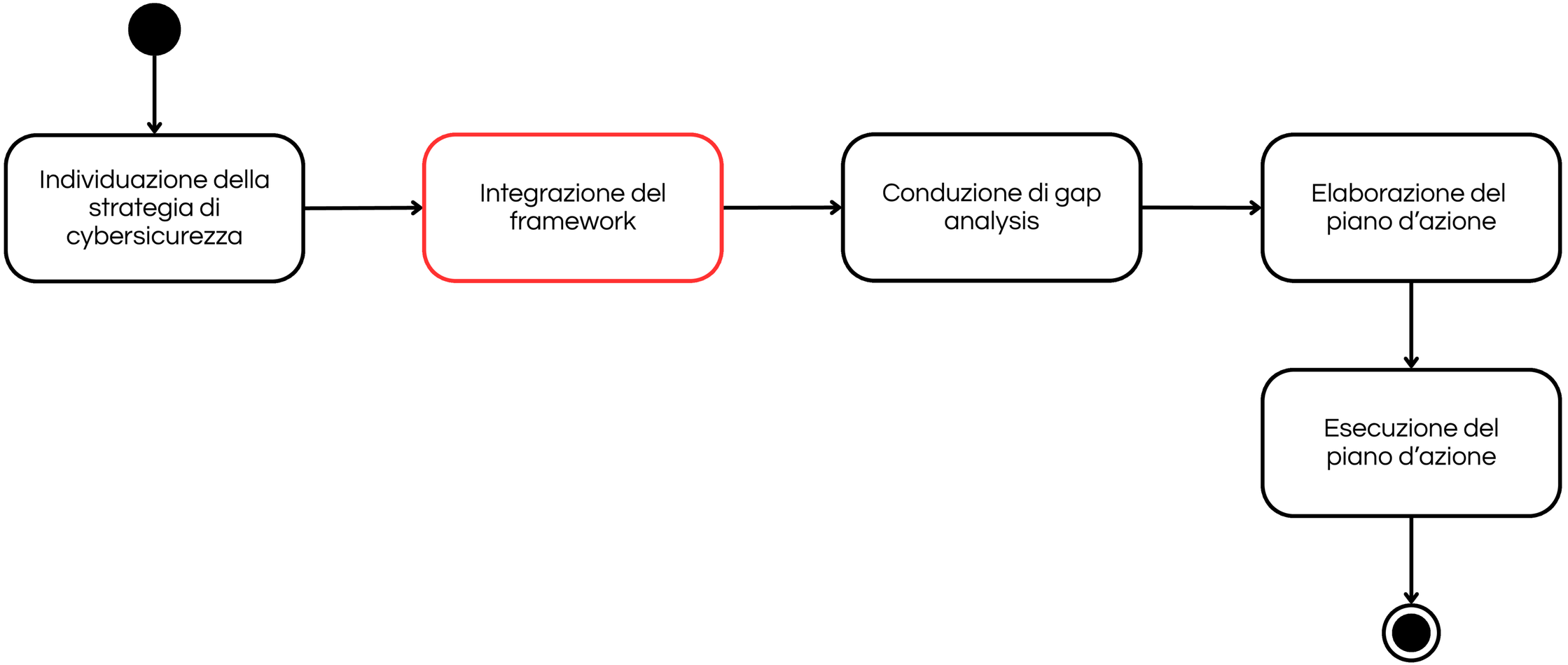
- Governance e gestione del rischio
- Security by design
- Operations security
- Security innovation
- Training e awareness

- Responsabile dell'implementazione delle misure per gli adempimenti NIS2
- Punto di contatto NIS2
- Obblighi informativi verso il CdA
- Collaborazione con tutte le funzioni aziendali

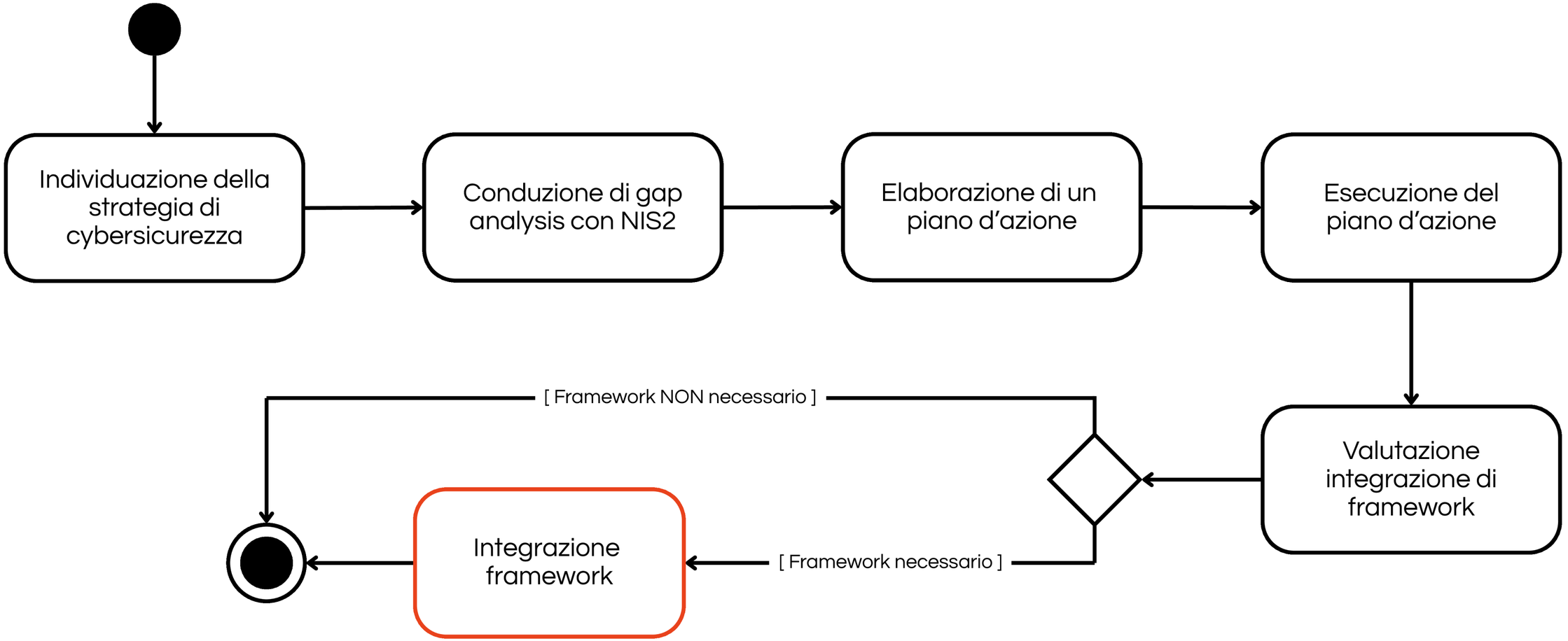


Responsabilità NIS2

Implementazione di NIS2 con framework



Implementazione diretta di NIS2

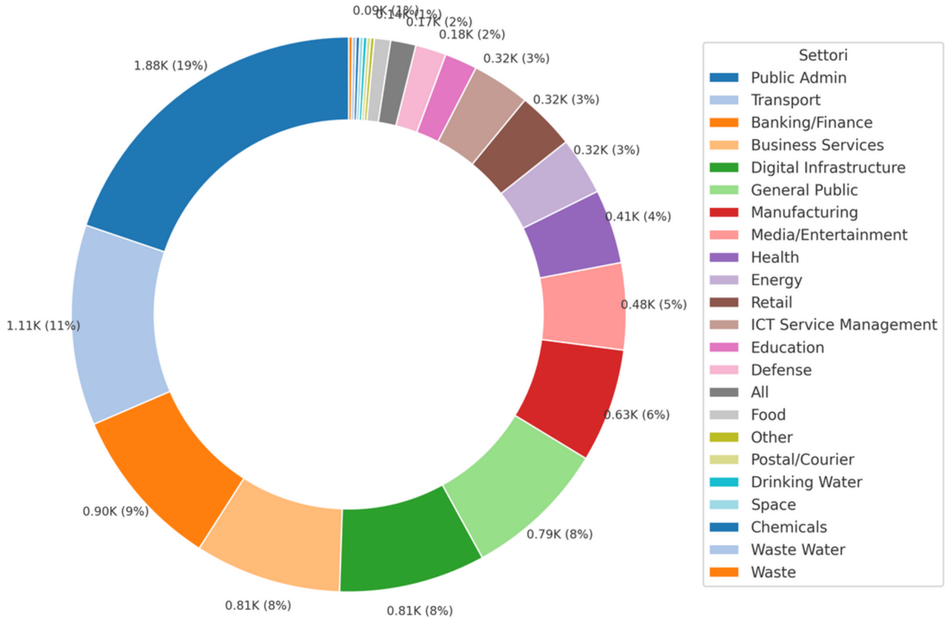


FINE

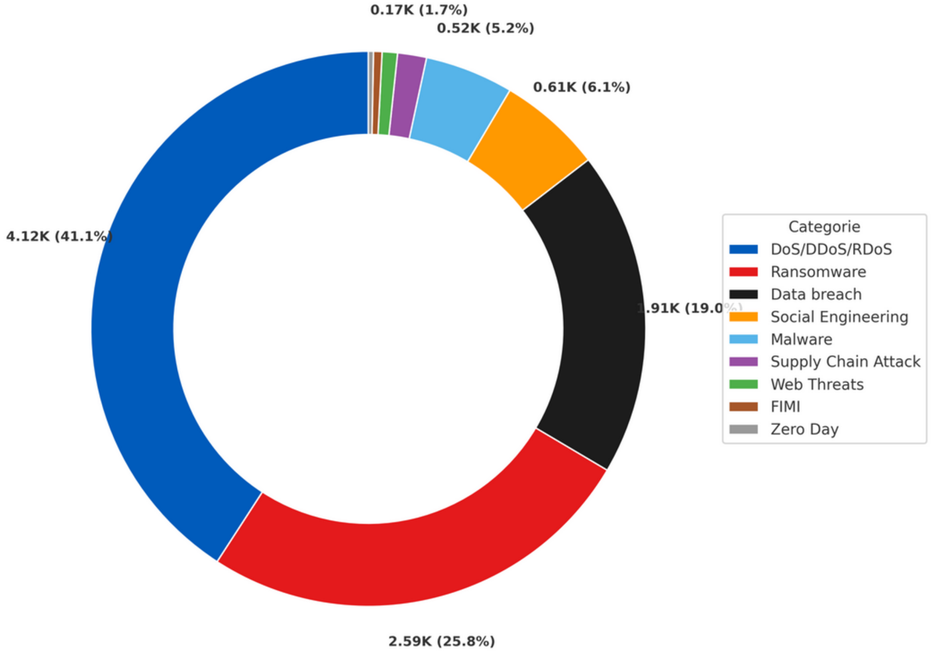
grazie

Scenario cyber in Europa

Ripartizione degli incidenti per tipologia di minaccia



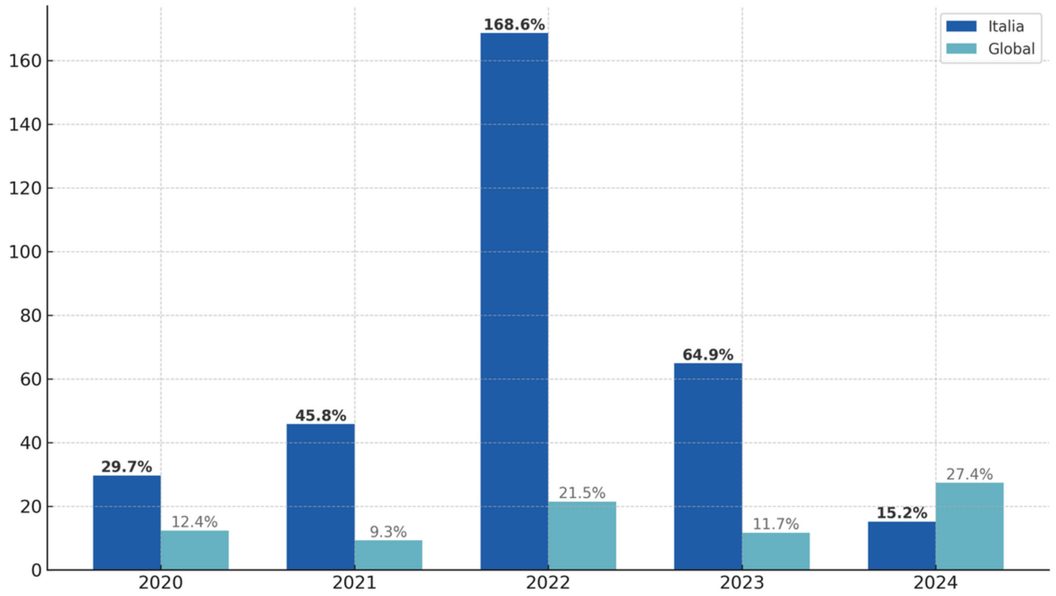
Ripartizione degli incidenti per settore



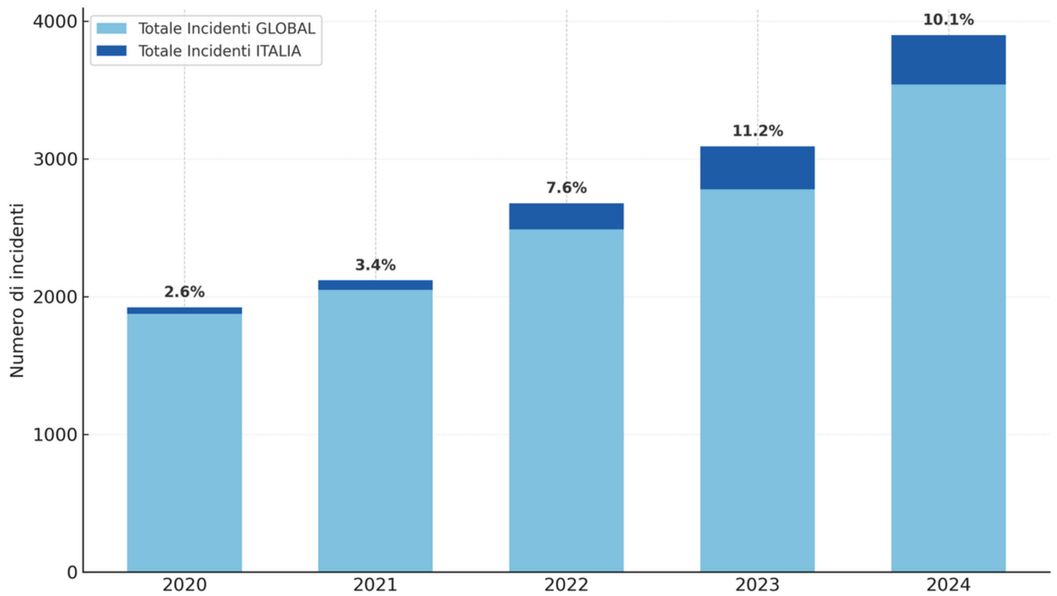
Fonte: Enisa Threat Landscape 2024

Scenario cyber in Italia

Crescita percentuale degli incidenti in Italia
a confronto con il resto del mondo



Percentuale di incidenti in Italia
rispetto al dato globale



Fonte: Rapporto Clusit 2025

Standard, framework e normative

NIST Cyber Security Framework v2.0
aggiornamento della versione precedente del 2014

Regolamento (UE) 2016/679 (GDPR)

Regolamento (UE) 2024/1689 (AI Act)



Standard ISO/IEC 27001:2022
ultima versione

Regolamento (UE) 2022/2544 (DORA)

Direttiva (UE) 2022/2555 (NIS2)

Soggetti NIS2

Settore	Grandi imprese	Medie imprese	Piccole e micro imprese
Settori altamente critici			
Energia, trasporti, **bancario***, **finanziario***, sanitario, acqua potabile, acque reflue, servizi TIC, spazio	**Essenziali**	**Importanti**	**Fuori ambito**
Infrastrutture digitali	**Essenziali**	*Ess. / imp. / f.a. a discrezione dell'autorità*	
Settori critici			
Posta, rifiuti, sostanze chimiche, alimentare, fabbricazione, ricerca	**Importanti**		**Fuori ambito**
Fornitori di servizi digitali	*Imp. / f.a. a discrezione dell'autorità*		
Ulteriori tipologie di soggetti			
PA centrale	**Essenziali**		
PA regionale e locale	**Importanti**		
Altri soggetti	**Identificazione dell'autorità**		

*regolamentati da DORA

Fonte: Agenzia per la Cybersicurezza Nazionale